

Rapport de Projet de Fin d'Études

AutoParts Pro

Réalisé par
Wiem Sayeh

Année Universitaire 2025-2026

Liste des acronymes

JWT	JSON Web Token
MSG	Management System Garage
RBAC	Role-Based Access Control
JWT	JSON Web Token

Table des matières

Liste des acronymes	1
Liste des figures	4
Liste des tableaux	5
Introduction Générale	6
1 Présentation générale	7
2 Réalisation du Sprint 1 : Gestion des utilisateurs et Authentification	8
2.1 Introduction	8
2.2 Analyse du Sprint	8
2.2.1 Sprint Backlog	8
2.3 Diagramme de Cas d'Utilisation	10
2.3.1 Description des Cas d'Utilisation Principaux	11
2.4 Conception	14
2.4.1 Diagramme de Séquence : Création d'un Employé	14
2.4.2 Diagramme de Classes	15
2.5 Architecture de Sécurité	16
2.5.1 Architecture Spring Security	17
2.5.2 Authentification basée sur JWT	18
2.5.3 Gestion des rôles et des autorisations	19
2.6 Réalisation	20
2.6.1 Inscription d'un Customer et vérification du compte par e-mail . . .	21
2.6.2 Authentification des utilisateurs	21
2.6.3 Réinitialisation du mot de passe	21
2.6.4 Création et initialisation d'un Employee	21
2.7 Bilan du Sprint	21
3 Conception	23
4 Réalisation	24

Conclusion Générale	25
Bibliographie	26

Table des figures

2.1	Diagramme de cas d'utilisation global du Sprint 1	11
2.2	Diagramme de séquence - Création d'un employé	15
2.3	Diagramme de classes - Gestion des utilisateurs	16
2.4	Architecture de sécurité basée sur Spring Security et JWT	17

Liste des tableaux

2.1	Sprint Backlog - Gestion des utilisateurs et sécurité	10
2.2	Permissions des employés selon le département	20

Introduction Générale

Bienvenue dans mon rapport de Projet de Fin d'Études.

Chapitre 1

Présentation générale

Votre texte ici.

Chapitre 2

Réalisation du Sprint 1 : Gestion des utilisateurs et Authentification

2.1 Introduction

Ce premier sprint a pour objectif de mettre en place le système de gestion des utilisateurs ainsi que les mécanismes de sécurisation de l'application MSG. Il constitue la base de la plateforme en assurant l'authentification des différents acteurs, la protection des ressources et le contrôle des accès selon les rôles attribués.

La solution développée repose sur **Spring Security** et l'authentification par **JSON Web Token (JWT)** afin de garantir un accès sécurisé aux différentes fonctionnalités de l'application. Ce sprint couvre également l'inscription des clients, la vérification de l'adresse e-mail, la gestion des mots de passe, la création des employés par l'administrateur ainsi que la gestion des autorisations en fonction des rôles et des départements.

2.2 Analyse du Sprint

Cette section présente l'analyse du premier sprint consacré à la gestion des utilisateurs et à la sécurisation de l'application MSG. Elle décrit les fonctionnalités retenues dans le Sprint Backlog ainsi que les principaux cas d'utilisation réalisés afin de répondre aux besoins des différents acteurs du système.

2.2.1 Sprint Backlog

Le Sprint Backlog regroupe l'ensemble des fonctionnalités sélectionnées pour le premier sprint. Chaque fonctionnalité est exprimée sous forme de User Story, permettant de décrire les besoins des utilisateurs du système ainsi que la valeur apportée par chaque fonctionnalité développée.

L'objectif principal de ce sprint est de mettre en place une architecture d'authentification sécurisée, la gestion des utilisateurs et le contrôle des accès selon les rôles.

ID	User Story	Critère d'acceptation	Priorité
US1	En tant que système, je souhaite initialiser automatiquement un compte administrateur principal au premier démarrage afin de garantir l'accès initial à la plateforme MSG.	Le compte Admin est créé automatiquement avec un rôle administrateur et les permissions nécessaires. La création est effectuée uniquement si aucun compte administrateur n'existe dans la base de données.	Haute
US2	En tant que Customer, je souhaite créer un compte afin d'accéder aux services de l'application MSG.	Le compte est créé et un e-mail de vérification est envoyé.	Haute
US3	En tant que Customer, je souhaite vérifier mon adresse e-mail afin d'activer mon compte.	Le compte est activé après validation du lien reçu par e-mail.	Moyenne
US4	En tant que Customer, je souhaite me connecter afin d'accéder aux fonctionnalités qui me sont autorisées.	Une authentification réussie génère un jeton JWT.	Haute
US5	En tant qu'utilisateur, je souhaite réinitialiser mon mot de passe lorsque je l'ai oublié.	Un e-mail contenant un lien de réinitialisation est envoyé.	Moyenne
US6	En tant qu'Admin, je souhaite me connecter à la plateforme afin d'administrer le système.	L'administrateur est authentifié et accède au tableau de bord d'administration.	Haute
US7	En tant qu'Admin, je souhaite créer un compte employé afin de lui donner accès à la plateforme.	Le compte employé est créé avec un rôle et un département puis les identifiants sont envoyés par e-mail.	Haute

ID	User Story	Critère d'acceptation	Priorité
US8	En tant qu'Employee, je souhaite définir un nouveau mot de passe lors de ma première connexion afin de sécuriser mon compte.	Le mot de passe est modifié et le compte est activé.	Moyenne
US9	En tant qu'Employee, je souhaite me connecter afin d'accéder aux fonctionnalités correspondant à mon département.	L'authentification réussie génère un JWT contenant les informations du rôle et du département.	Haute
US10	En tant qu'Administrateur, je souhaite attribuer un rôle et un département à chaque employé afin de contrôler les autorisations d'accès.	Les permissions sont appliquées conformément au rôle et au département attribués.	Moyenne
US11	En tant qu'utilisateur authentifié, je souhaite que mes accès soient contrôlés selon mon rôle afin de protéger les ressources de l'application.	Les accès sont autorisés ou refusés par Spring Security en fonction des rôles et permissions.	Haute

TABLE 2.1 – Sprint Backlog - Gestion des utilisateurs et sécurité

2.3 Diagramme de Cas d'Utilisation

Le diagramme de cas d'utilisation présente les fonctionnalités liées à la gestion des utilisateurs et à la sécurisation de l'application MSG. Il décrit les interactions entre les différents acteurs du système et les services d'authentification disponibles.

Le système implique trois acteurs principaux :

- **Customer** : peut créer un compte, vérifier son adresse e-mail, se connecter et réinitialiser son mot de passe.
- **Admin** : peut se connecter, réinitialiser son mot de passe, créer des comptes Employee et gérer leurs rôles et permissions.
- **Employee** : reçoit ses informations de connexion après sa création, définit son mot de passe, se connecte et utilise les fonctionnalités autorisées selon son rôle.

Les principaux cas d'utilisation réalisés dans ce sprint sont :

- Register Customer
- Verify Email
- Login
- Forgot Password
- Reset Password
- Create Employee
- Manage Roles and Permissions

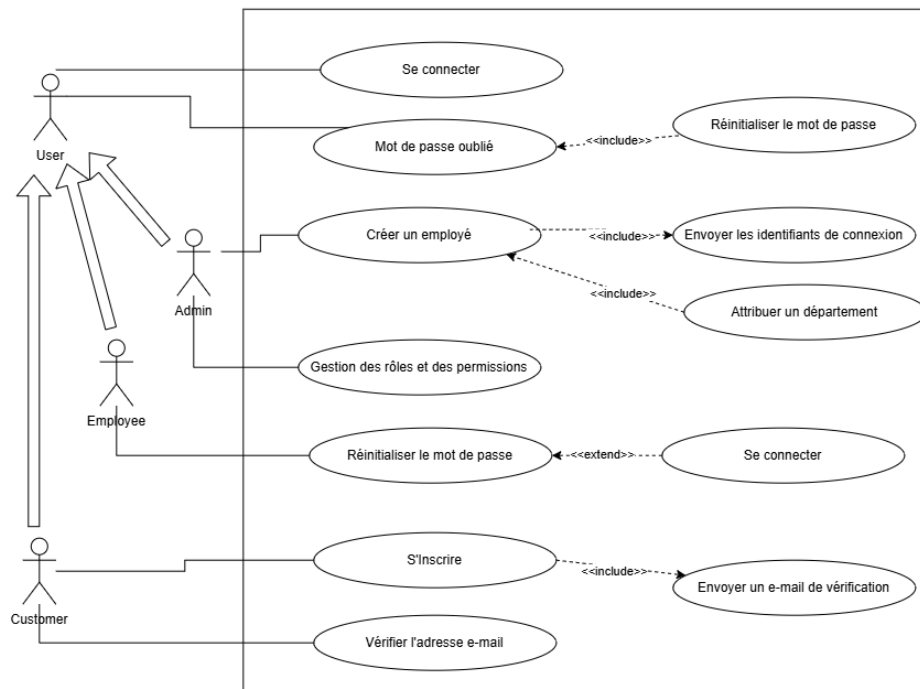


FIGURE 2.1 – Diagramme de cas d'utilisation global du Sprint 1

2.3.1 Description des Cas d'Utilisation Principaux

UC1 : Se connecter

Description :

Ce cas d'utilisation permet à un utilisateur (Customer, Employee ou Admin) de s'authentifier afin d'accéder aux fonctionnalités qui lui sont autorisées.

Préconditions :

- L'utilisateur possède un compte actif.
- Les identifiants de connexion sont valides.

Scénario nominal :

1. L'utilisateur accède à la page de connexion.
2. Il saisit son adresse e-mail et son mot de passe.

3. Le système vérifie les informations d'authentification.
4. Le système authentifie l'utilisateur.
5. L'utilisateur accède à son espace de travail.

Postconditions :

- L'utilisateur est authentifié.
- Les fonctionnalités correspondant à son rôle sont accessibles.

UC2 : Mot de passe oublié

Description :

Ce cas d'utilisation permet à un utilisateur ayant oublié son mot de passe de demander sa réinitialisation.

Préconditions :

- L'utilisateur possède un compte.
- L'adresse e-mail est enregistrée dans le système.

Scénario nominal :

1. L'utilisateur sélectionne l'option « Mot de passe oublié ».
2. Il saisit son adresse e-mail.
3. Le système vérifie l'existence du compte.
4. Le système exécute le cas d'utilisation *Réinitialiser le mot de passe*.

Postconditions :

- La procédure de réinitialisation est lancée.

UC3 : Créer un employé

Description :

Ce cas d'utilisation permet à l'Admin de créer un compte Employee afin de lui donner accès à l'application.

Préconditions :

- L'Admin est authentifié.
- L'Admin possède les droits nécessaires.

Scénario nominal :

1. L'Admin saisit les informations de l'Employee.
2. Le système crée le compte Employee.
3. Le système exécute le cas d'utilisation *Attribuer un département*.
4. Le système exécute le cas d'utilisation *Envoyer les identifiants de connexion*.

Postconditions :

- Le compte Employee est créé.
- Le département est attribué.
- Les identifiants de connexion sont envoyés à l'Employee.

UC4 : Gestion des rôles et des permissions

Description :

Ce cas d'utilisation permet à l'Admin de gérer les rôles et les permissions des employés afin de contrôler les accès aux différentes fonctionnalités du système.

Préconditions :

- L'Admin est authentifié.
- L'Admin possède les droits d'administration.

Scénario nominal :

1. L'Admin consulte la liste des rôles.
2. Il sélectionne un employé.
3. Il attribue ou modifie le rôle et les permissions.
4. Le système enregistre les modifications.

Postconditions :

- Les rôles et permissions de l'employé sont mis à jour.

UC5 : S'inscrire

Description :

Ce cas d'utilisation permet à un Customer de créer un compte afin d'accéder aux services de l'application.

Préconditions :

- Le Customer ne possède pas déjà un compte.
- Le formulaire d'inscription est accessible.

Scénario nominal :

1. Le Customer accède au formulaire d'inscription.
2. Il saisit ses informations personnelles.
3. Le système valide les informations.
4. Le système crée le compte.
5. Le système exécute le cas d'utilisation *Envoyer un e-mail de vérification*.

Postconditions :

- Le compte est enregistré.
- Le compte reste inactif jusqu'à la vérification de l'adresse e-mail.

UC6 : Vérifier l'adresse e-mail

Description :

Ce cas d'utilisation permet au Customer d'activer son compte en validant son adresse e-mail à l'aide du lien reçu.

Préconditions :

- Le compte Customer existe.
- Un e-mail de vérification a été envoyé.

Scénario nominal :

1. Le Customer ouvre le lien reçu par e-mail.
2. Le système vérifie la validité du token.
3. Le système active le compte.
4. Le système confirme la vérification de l'adresse e-mail.

Postconditions :

- Le compte est activé.
- Le Customer peut se connecter à l'application.

2.4 Conception

Cette section présente la conception détaillée des fonctionnalités développées durant le premier sprint. Elle décrit les interactions entre les différents composants du système ainsi que la structure des principales entités utilisées pour la gestion des utilisateurs et la sécurisation de l'application MSG.

2.4.1 Diagramme de Séquence : Création d'un Employé

Le diagramme de séquence suivant illustre le processus de création d'un nouvel employé par l'administrateur. Cette fonctionnalité permet à l'Admin d'enregistrer un employé, de lui attribuer un rôle et un département, puis de lui envoyer ses informations de connexion par e-mail.

Le scénario principal est le suivant :

- L'Admin accède à l'interface de création d'un employé.
- Il saisit les informations personnelles de l'employé.
- Le système vérifie la validité des données saisies.
- Le contrôleur reçoit la requête de création.
- Le service métier applique les règles de gestion.
- Le compte employé est enregistré dans la base de données.
- Le rôle et le département sont associés à l'employé.
- Un e-mail contenant les identifiants de connexion est envoyé à l'employé.

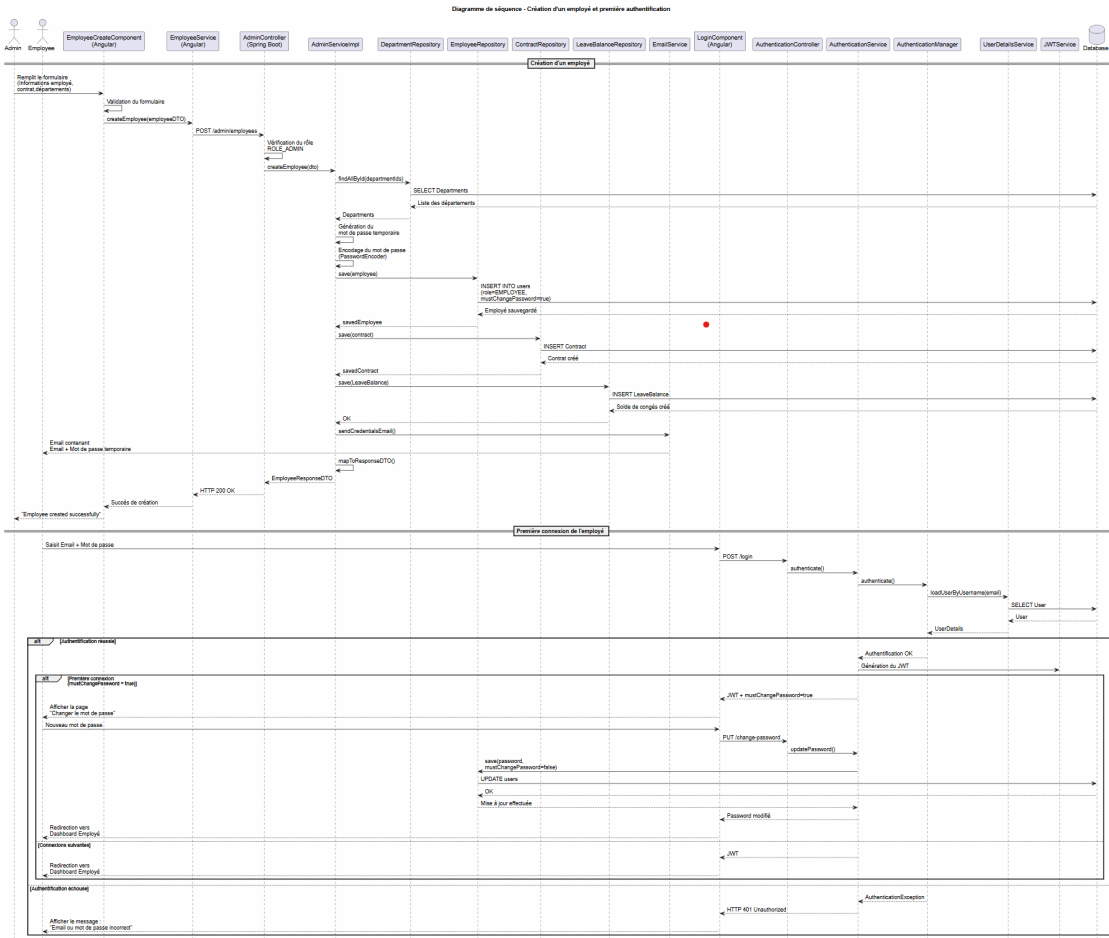


FIGURE 2.2 – Diagramme de séquence - Création d'un employé

2.4.2 Diagramme de Classes

Le diagramme de classes présente la structure statique du module de gestion des utilisateurs. Il décrit les principales entités manipulées par l'application ainsi que les relations entre elles.

Les principales classes représentées sont :

- **User** : représente la classe principale contenant les informations communes des utilisateurs.
- **Customer** : représente les clients inscrits sur la plateforme.
- **Employee** : représente les employés créés par l'administrateur.
- **Admin** : représente l'administrateur responsable de la gestion du système.
- **Role** : permet de définir les droits d'accès associés aux utilisateurs.
- **Department** : représente le département auquel un employé appartient.
- **Token** : permet de gérer les mécanismes de vérification d'e-mail et de réinitialisation du mot de passe.

Les relations principales sont :

- Un utilisateur possède un rôle définissant ses permissions.

- Un employé appartient à un département.
- Un utilisateur peut posséder plusieurs tokens pour les opérations de sécurité.
- L'administrateur peut créer et gérer les comptes employés.

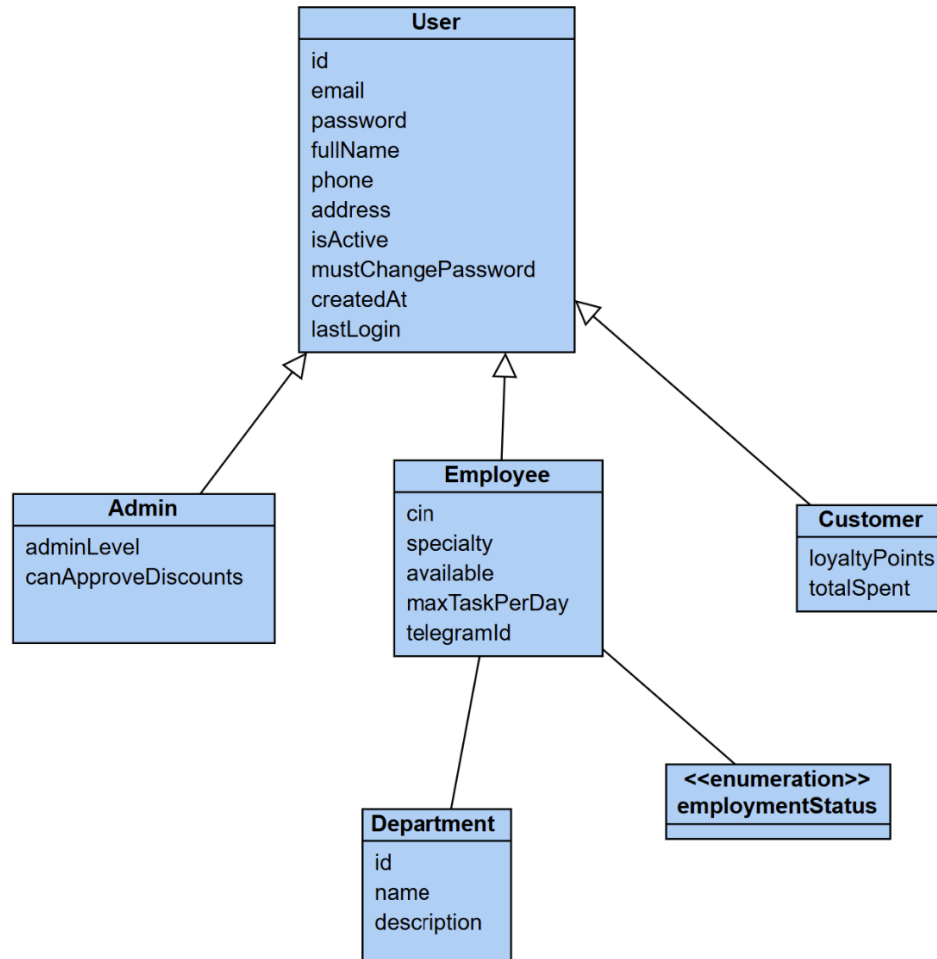


FIGURE 2.3 – Diagramme de classes - Gestion des utilisateurs

2.5 Architecture de Sécurité

La sécurité de l'application Management System Garage (MSG) repose sur l'intégration de *Spring Security* et du mécanisme d'authentification basé sur le JSON Web Token (JWT) (*JSON Web Token*). Cette architecture permet d'assurer l'authentification des utilisateurs, la protection des ressources exposées par les API REST ainsi que le contrôle des accès en fonction des rôles attribués à chaque utilisateur.

Comme illustré par la Figure 2.4, le processus de sécurité débute lors de la connexion de l'utilisateur. Après vérification des informations d'authentification, un jeton JWT est généré puis transmis au client. Ce jeton est ensuite utilisé pour accéder aux ressources

protégées, où il est systématiquement vérifié avant l'autorisation de chaque requête.

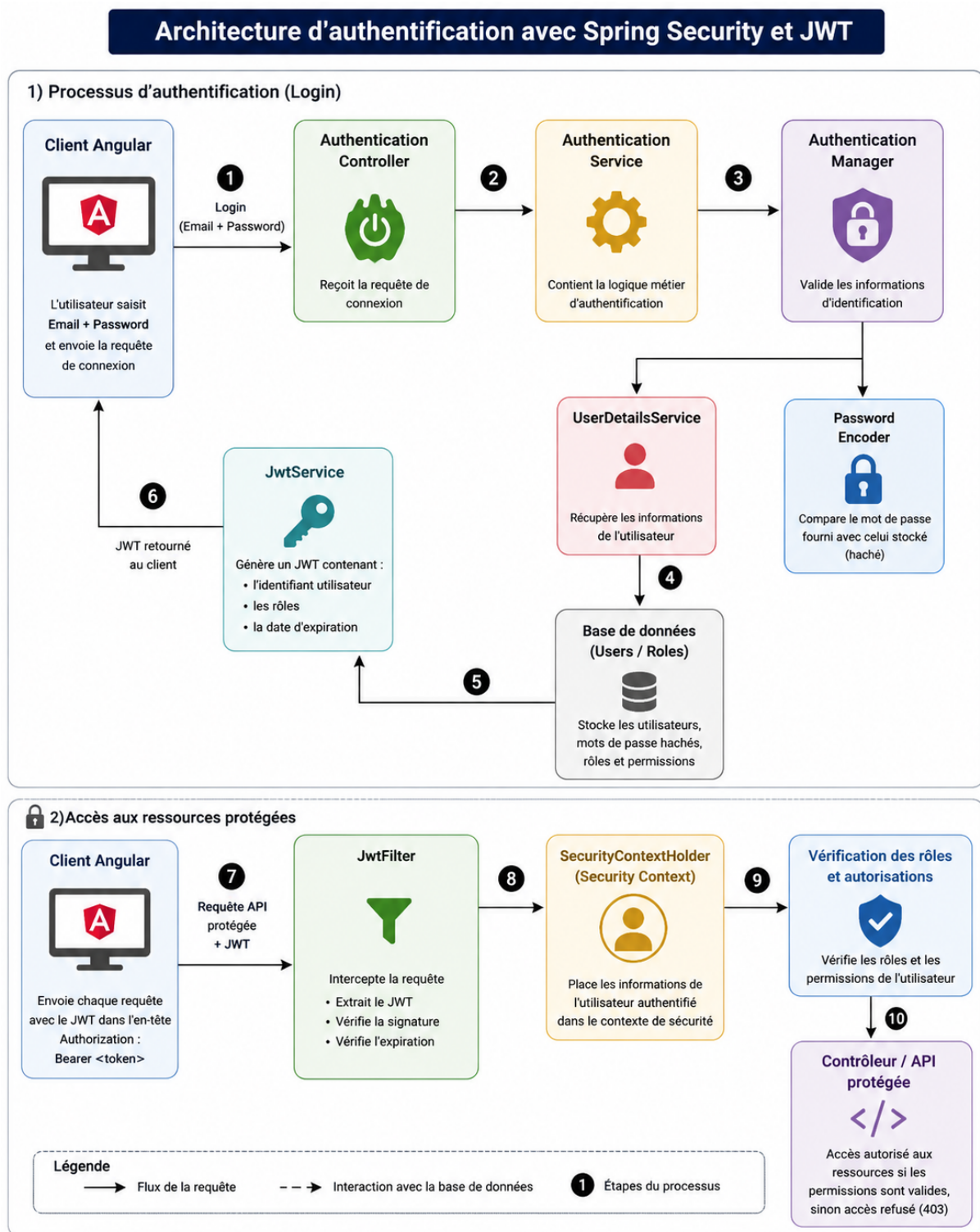


FIGURE 2.4 – Architecture de sécurité basée sur Spring Security et JWT

2.5.1 Architecture Spring Security

Spring Security est un framework dédié à la sécurisation des applications Spring. Dans l'application MSG, il prend en charge l'authentification des utilisateurs, la protection des

API et le contrôle des autorisations en fonction des rôles.

Son fonctionnement repose principalement sur les composants suivants.

Security Filter Chain

La *Security Filter Chain* intercepte chaque requête HTTP avant son traitement par l'application. Elle vérifie la présence et la validité du JWT, identifie l'utilisateur authentifié et autorise ou refuse l'accès aux ressources protégées.

Authentication Provider

L'*Authentication Provider* est chargé de valider les informations de connexion. Il recherche l'utilisateur dans la base de données, compare le mot de passe fourni avec celui enregistré et confirme l'identité de l'utilisateur.

UserDetailsService

Le composant *UserDetailsService* récupère les informations nécessaires à l'authentification depuis la base de données, notamment l'identifiant, le mot de passe chiffré ainsi que les rôles associés à l'utilisateur.

PasswordEncoder

Le *PasswordEncoder* assure le chiffrement des mots de passe avant leur stockage et permet une comparaison sécurisée lors de l'authentification, garantissant ainsi qu'aucun mot de passe n'est conservé en clair.

Les mécanismes de sécurité présentés s'appuient sur les recommandations de Spring Security [1, 2].

2.5.2 Authentification basée sur JWT

Le JWT (*JSON Web Token*) est un standard permettant de transmettre de manière sécurisée les informations d'authentification entre le client et le serveur. Contrairement à une authentification basée sur les sessions, cette approche est *stateless* : le serveur ne conserve pas l'état de connexion des utilisateurs, les informations nécessaires étant contenues dans le jeton.

Le processus d'authentification se déroule selon les étapes suivantes.

1. L'utilisateur saisit son adresse e-mail et son mot de passe, qui sont envoyés au serveur.
2. Les identifiants sont vérifiés à l'aide du *UserDetailsService* et du *PasswordEncoder*. Si les informations sont valides, l'utilisateur est authentifié.

3. Le service *JwtService* génère un jeton JWT contenant l'identifiant de l'utilisateur, son rôle ainsi que sa date d'expiration.
4. Lors de chaque requête vers une ressource protégée, le client transmet ce jeton dans l'en-tête HTTP **Authorization**. Le filtre JWT valide alors le jeton avant de permettre l'accès à la ressource demandée.

Cette approche améliore les performances des applications distribuées en supprimant la gestion des sessions côté serveur tout en garantissant un niveau élevé de sécurité des échanges [3].

2.5.3 Gestion des rôles et des autorisations

Afin de garantir un contrôle d'accès sécurisé, l'application MSG met en œuvre un modèle de contrôle d'accès basé sur les rôles (*Role-Based Access Control* - Role-Based Access Control (RBAC)). Dans cette approche, les permissions ne sont pas attribuées directement aux utilisateurs, mais aux rôles qui leur sont associés. Chaque utilisateur hérite ainsi des autorisations correspondant à son rôle.

Le modèle RBAC utilisé dans MSG repose sur les principes suivants :

- chaque utilisateur est associé à un rôle ;
- chaque rôle définit un ensemble de fonctionnalités accessibles ;
- les permissions déterminent les actions autorisées sur les différentes ressources de l'application.

Les principaux rôles implémentés dans l'application sont présentés ci-dessous.

Rôle ADMIN

Le rôle **ADMIN** correspond au responsable de l'administration de l'application. Il dispose de l'ensemble des privilèges nécessaires pour gérer le système.

Ses principales permissions sont :

- authentification ;
- gestion des comptes des employés ;
- attribution des rôles ;
- gestion des départements ;
- accès à l'ensemble des fonctionnalités administratives.

Rôle CUSTOMER

Le rôle **CUSTOMER** représente le client utilisant la plateforme. Il dispose uniquement des fonctionnalités destinées aux utilisateurs externes.

Ses principales fonctionnalités sont :

- création d'un compte ;

- vérification de l'adresse e-mail ;
- authentification ;
- réinitialisation du mot de passe ;
- accès aux services proposés aux clients.

Rôle **EMPLOYEE**

Le rôle **EMPLOYEE** est attribué aux utilisateurs internes créés par l'administrateur. Chaque employé est associé à un département qui détermine les fonctionnalités auxquelles il peut accéder.

Son profil est défini par :

- un rôle ;
- un département ;
- un ensemble de permissions spécifiques.

En complément du modèle RBAC, MSG applique une restriction supplémentaire basée sur le département de l'employé afin de limiter l'accès aux fonctionnalités métier.

Département	Permissions
Sales	Gestion des produits, consultation du stock et gestion des fournisseurs.
Mechanic	Gestion des demandes de maintenance et des interventions techniques.
HR	Gestion des employés, des congés et des avances sur salaire.
Admin	Accès à l'ensemble des fonctionnalités de l'application.

TABLE 2.2 – Permissions des employés selon le département

L'association entre les rôles et les permissions permet d'assurer un contrôle d'accès cohérent et sécurisé, tout en garantissant que chaque utilisateur n'accède qu'aux fonctionnalités nécessaires à ses responsabilités. Cette approche facilite également l'administration des droits d'accès et améliore la sécurité globale de l'application [4].

2.6 Réalisation

Cette section présente les principales fonctionnalités développées au cours de ce sprint concernant la gestion des utilisateurs et la sécurisation de l'application MSG. Elle décrit les différentes interfaces réalisées pour l'inscription des clients, l'authentification des utilisateurs, la réinitialisation des mots de passe ainsi que la création et la gestion des comptes des employés.

2.6.1 Inscription d'un Customer et vérification du compte par e-mail

Le processus d'inscription permet à un **Customer** de créer un compte dans l'application en renseignant les informations demandées dans le formulaire d'inscription. Après validation des données, le système enregistre le nouvel utilisateur puis envoie automatiquement un e-mail de confirmation contenant un lien de vérification. Le compte n'est activé qu'après la validation de cette adresse électronique.

2.6.2 Authentification des utilisateurs

L'interface de connexion permet aux différents utilisateurs de l'application (**Customer**, **Admin** et **Employee**) d'accéder à leurs espaces respectifs. Après la saisie des identifiants, Spring Security vérifie les informations de connexion puis génère un jeton JWT permettant d'accéder aux ressources protégées. Selon le rôle de l'utilisateur, celui-ci est automatiquement redirigé vers son interface dédiée.

2.6.3 Réinitialisation du mot de passe

L'application offre une fonctionnalité permettant aux utilisateurs de récupérer l'accès à leur compte lorsqu'ils oublient leur mot de passe. L'utilisateur renseigne son adresse e-mail afin de recevoir un lien sécurisé de réinitialisation. Ce lien permet ensuite de définir un nouveau mot de passe.

2.6.4 Création et initialisation d'un Employee

Contrairement au **Customer**, un **Employee** ne crée pas son compte lui-même. Celui-ci est créé par l'**Admin** à partir de l'interface de gestion des employés. Lors de cette création, les informations de connexion sont automatiquement envoyées par courrier électronique. À sa première connexion, l'employé utilise les identifiants reçus afin d'accéder à son espace de travail.

2.7 Bilan du Sprint

Ce premier sprint a permis de mettre en place les fondations nécessaires pour assurer la sécurité et la gestion des utilisateurs au sein de l'application MSG.

Les fonctionnalités développées ont permis d'intégrer un système d'authentification sécurisé basé sur **Spring Security** et **JSON Web Token (JWT)**. Cette architecture garantit la protection des ressources de l'application et assure un contrôle d'accès selon les rôles attribués aux différents utilisateurs.

Au cours de ce sprint, plusieurs fonctionnalités essentielles ont été réalisées, notamment la création de comptes clients, la vérification des adresses e-mail, la gestion de la réinitialisation des mots de passe ainsi que la création des comptes employés par l'administrateur.

La gestion des autorisations a également été mise en place à travers l'attribution des rôles et des départements, permettant d'adapter les accès aux différentes fonctionnalités selon le profil de chaque utilisateur (**Customer**, **Employee** et **Admin**).

Ainsi, ce sprint constitue une étape fondamentale dans la construction de la plateforme MSG en garantissant une base sécurisée, évolutive et prête à accueillir les fonctionnalités métiers développées dans les prochains sprints.

Chapitre 3

Conception

Votre texte ici.

Chapitre 4

Réalisation

Votre texte ici.

Conclusion Générale

Votre conclusion.

Bibliographie

- [1] VMware, “Spring security reference documentation,” 2024. [Online]. Available : <https://docs.spring.io/spring-security/reference/>
- [2] C. Walls, *Spring in Action*, 6th ed. Manning Publications, 2022.
- [3] M. Jones, J. Bradley, and N. Sakimura, “Rfc 7519 : Json web token (jwt),” 2015. [Online]. Available : <https://www.rfc-editor.org/rfc/rfc7519>
- [4] D. Ferraiolo and R. Kuhn, “Role-based access controls,” in *15th National Computer Security Conference*, 1992.